

CHAPTER 13

ENTITY AUTHENTICATION



Outlines

1. Password Authentication. 
2. Biometric Authentication.
3. Multi-Factor Authentication.

Learning Objectives

In the end of this Chapter 13, students will be able:

1. To understand the **concept and importance of entity authentication** in cryptography and data security.
2. To understand the describe several approaches in the **password authentication** in identifying an entity.
3. To understand the concept of **biometric authentication**.
4. To understand the concept of **multi-factor authentication** in cryptography and data security.



ENTITY **AUTHENTICATION** **(*OVERVIEW*)**

Entity Authentication – Overview

- **Entity authentication** is a technique designed to allow a person to **identify himself**, or to **prove the identity of another person**.
- Any one can authenticate himself (claimant) via one of the following three types of witnesses:
 1. **Something that a person knows**. A secret information that only known by the claimant that can be checked by the verifier. For example, password.
 2. **Something that a person has**. An object that provided by the claimant to prove his identity. For example, passport, ID card, and credit card.
 3. **Something that a person is**. An unique inherent characteristic of the claimant. For example, fingerprint, voice, and handwriting.

Entity Authentication – Overview

- **Differences** between **message authentication** and **entity authentication**:

Message Authentication	Entity Authentication
• Might not happen in real time. • The sender may not be present during message authentication by the receiver.	• It happens in real time. • Both sender and receiver must be present during authentication. • No real message communication involved until it is done.
• It only authenticates one message at a time.	• It authenticates the entity for the entire duration of the communication.



PASSWORD AUTHENTICATION

Password Authentication

- The oldest and simplest method of entity authentication, it is '**something**' **that the claimant knows**.
- Each user has a **user identification that is public**, and a **password that is private**.
- The password authentication can be categorized into two groups:
 1. **Fixed Password**. A password that is used over and over again for every access.
 2. **One-Time Password**. A password that is used only once.



PASSWORD AUTHENTICATION

FIXED PASSWORD



Fixed Password – First Approach

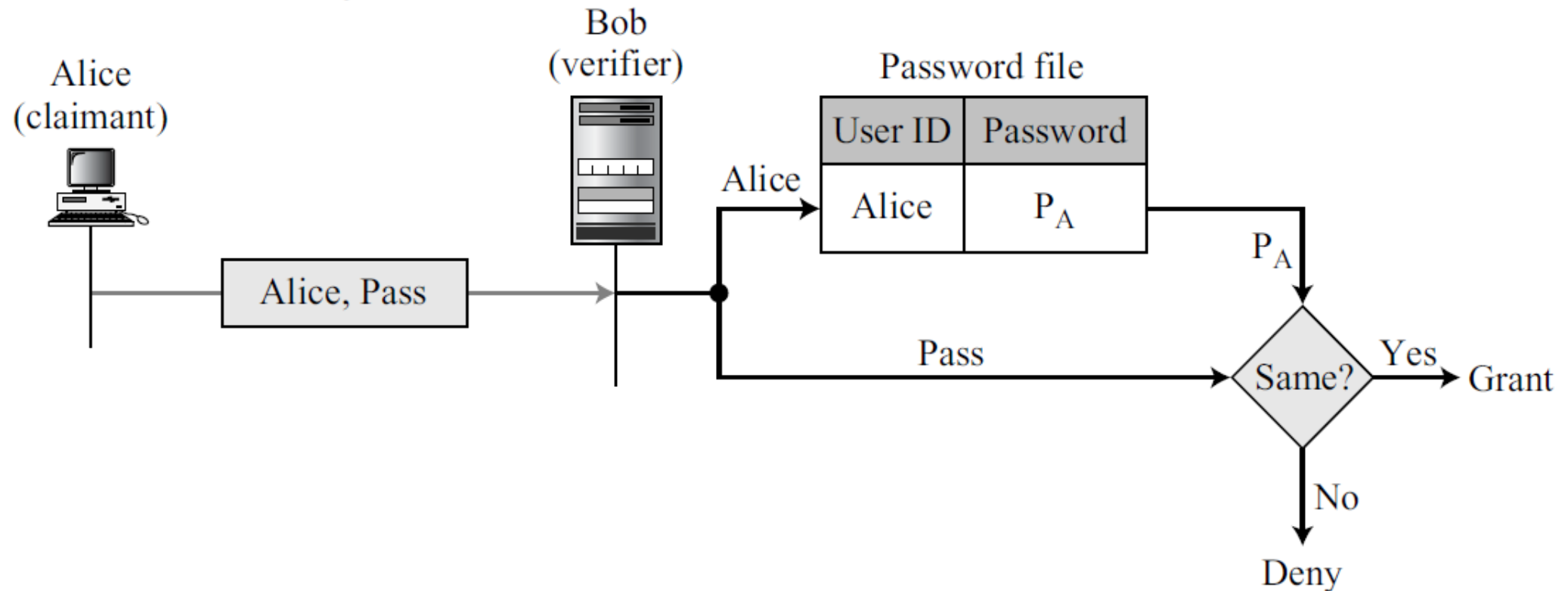
1. First Approach.

- The basic approach of password authentication.
- The system stores the password file containing **User ID** and **password (in plaintext form)**.
- To access the system resources, the user sends his User ID and password to the system. The system **search through** the password file and if there is a match, access is granted. Otherwise, it is denied.

Fixed Password – First Approach

P_A : Alice's stored password

Pass: Password sent by claimant



Fixed Password – Second Approach

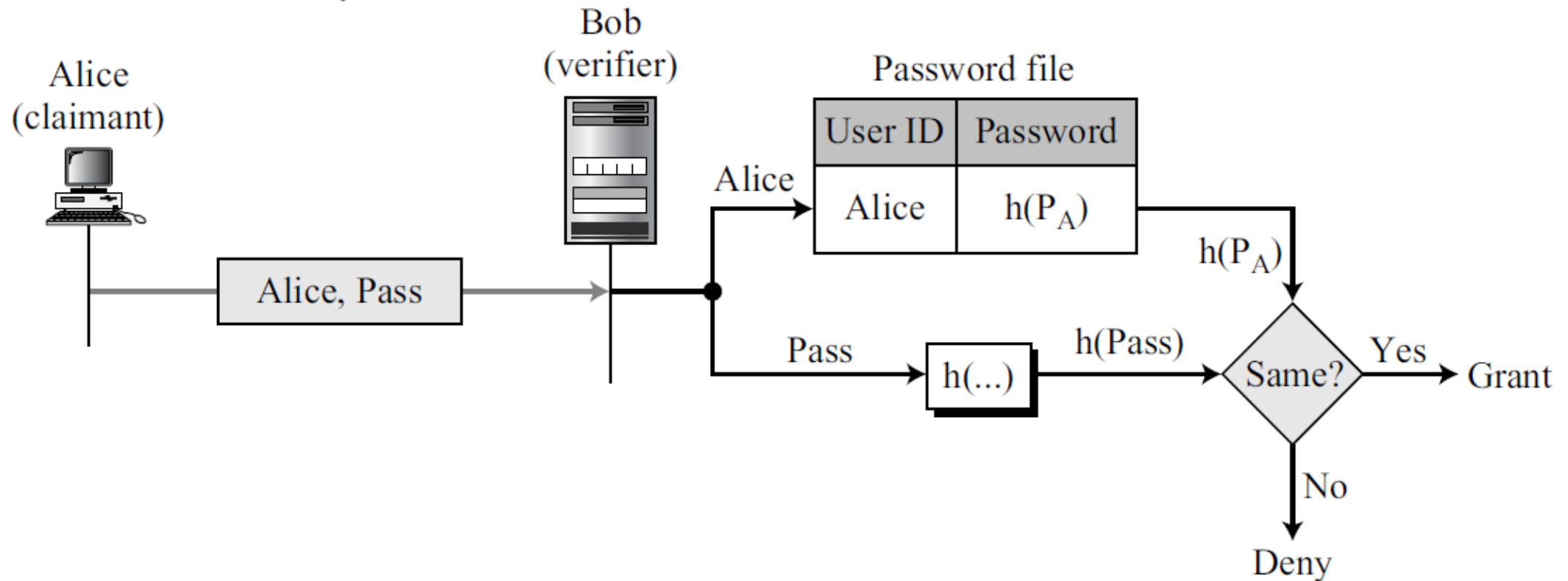
2. Second Approach.

- A more secure approach where the **password is hashed**.
- When the password is created for the first time by a user, the system hashes it and stores both the **User ID** and the corresponding **hashed password** in the password file.
- To access the system resources, the user sends his User ID and password to the system. The system **hashes the password and compares the hash stored in** the password file. If there is a match, access is granted. Otherwise, it is denied.

Fixed Password – Second Approach

P_A : Alice's stored password

Pass: Password sent by claimant



Fixed Password – Third Approach

3. Third Approach.

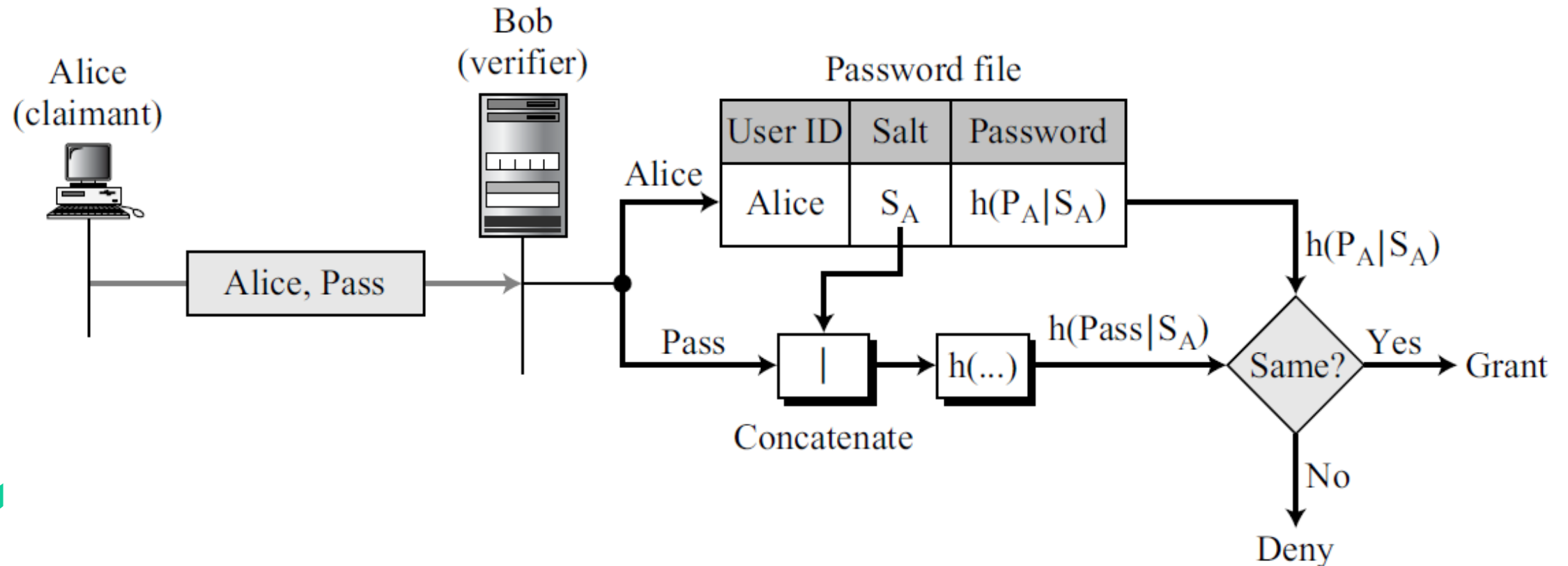
- In this approach, **a salt (random string)** is added into the password before hashing it.
- When the password is created for the first time by a user, a salt is concatenated with the password and is then hashed.
- The system stores the **User ID**, the **salt** and the corresponding **hashed salted password** in the password file.
- To access the system resources, the user sends his User ID and password to the system. The system **extract the salt, concatenate it with the password and hashes it**. It then **compares with the hash stored in** the password file. If there is a match, access is granted. Otherwise, it is denied.

Fixed Password – Third Approach

P_A : Alice's password

S_A : Alice's salt

Pass: Password sent by claimant





PASSWORD AUTHENTICATION

ONE-TIME PASSWORD



One-Time Password – **First** Approach

1. First Approach.

- The user and the system agree upon **a list of passwords**, with each password used only once.
- **Advantage:**
 - i. The scheme is secure from eavesdropping.
- **Drawbacks:**
 - i. The user and the system must keep a long list of password.
 - ii. If the user does not use the password in sequence, the system needs to perform a long search to find the match.

One-Time Password – Second Approach

2. Second Approach.

- The user and the system agree to **sequentially update the password**.
- The user and the system agree on an original password P_1 that valid for the first access. During the access, second new password **P_2 is generated and encrypted with P_1** . The same processes work for the subsequent access.
- Mathematically, P_i is used to create P_{i+1} .
- **Drawback:**
 - If Eve can guess the first password P_1 , then she can find out all the subsequent passwords.

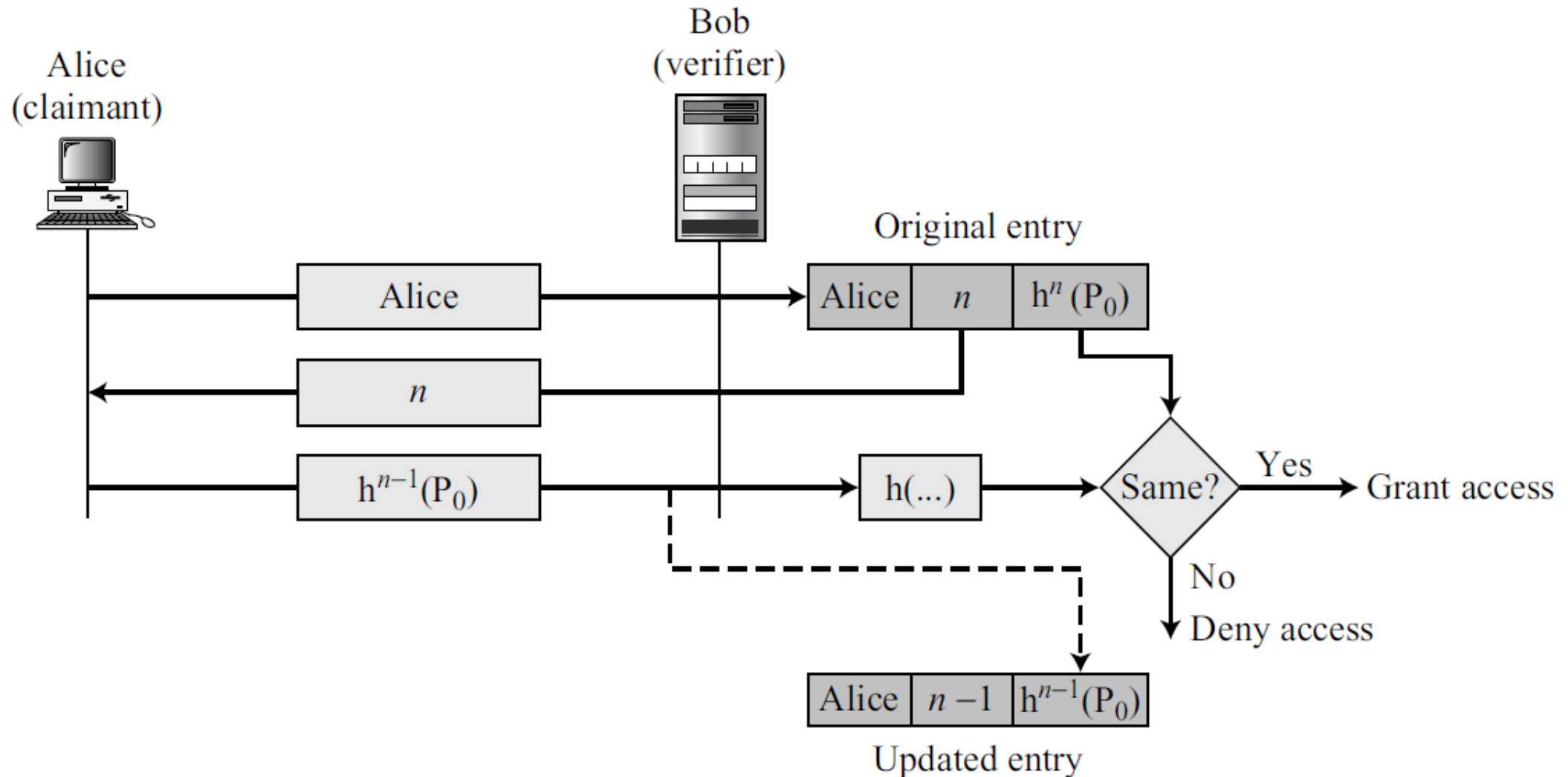
One-Time Password – Third Approach

3. Third Approach (Lamport One-Time Password).

- This approach was devised by Leslie Lamport in 1981, in which the user and the system **create a sequentially updated password using a hash function**.
- The user and the system initially agree upon an **original password P_0** and a **counter n** . The system **computes $h^n(P_0)$** , where h^n indicate **applying the hash function n times**.
- Mathematically,

$$\begin{aligned}h^n(P_0) &= h(h^{n-1}(P_0)) \\h^{n-1}(P_0) &= h(h^{n-2}(P_0)) \\&\vdots \\h^2(P_0) &= h(h(P_0)) \\h^1(P_0) &= h(P_0)\end{aligned}$$

One-Time Password – **Third** Approach



One-Time Password – Third Approach

- The system stores the **User ID**, the **counter n** , and the **value $h^n(P_0)$** in the password file.
- When the user sends her User ID for the first time, the system search through the password file to **extract and reply the counter n** . The user next responds by computing $h^{n-1}(P_0)$ to the system.
- The system **compute the LAST hash, checks and compares the $h^n(P_0)$ received with the value stored in password file**. If there is a match, access is granted. Otherwise, it is denied.
- The counter then **decreased by 1** and **$h^n(P_0)$ is replaced by $h^{n-1}(P_0)$** .

One-Time Password – Third Approach

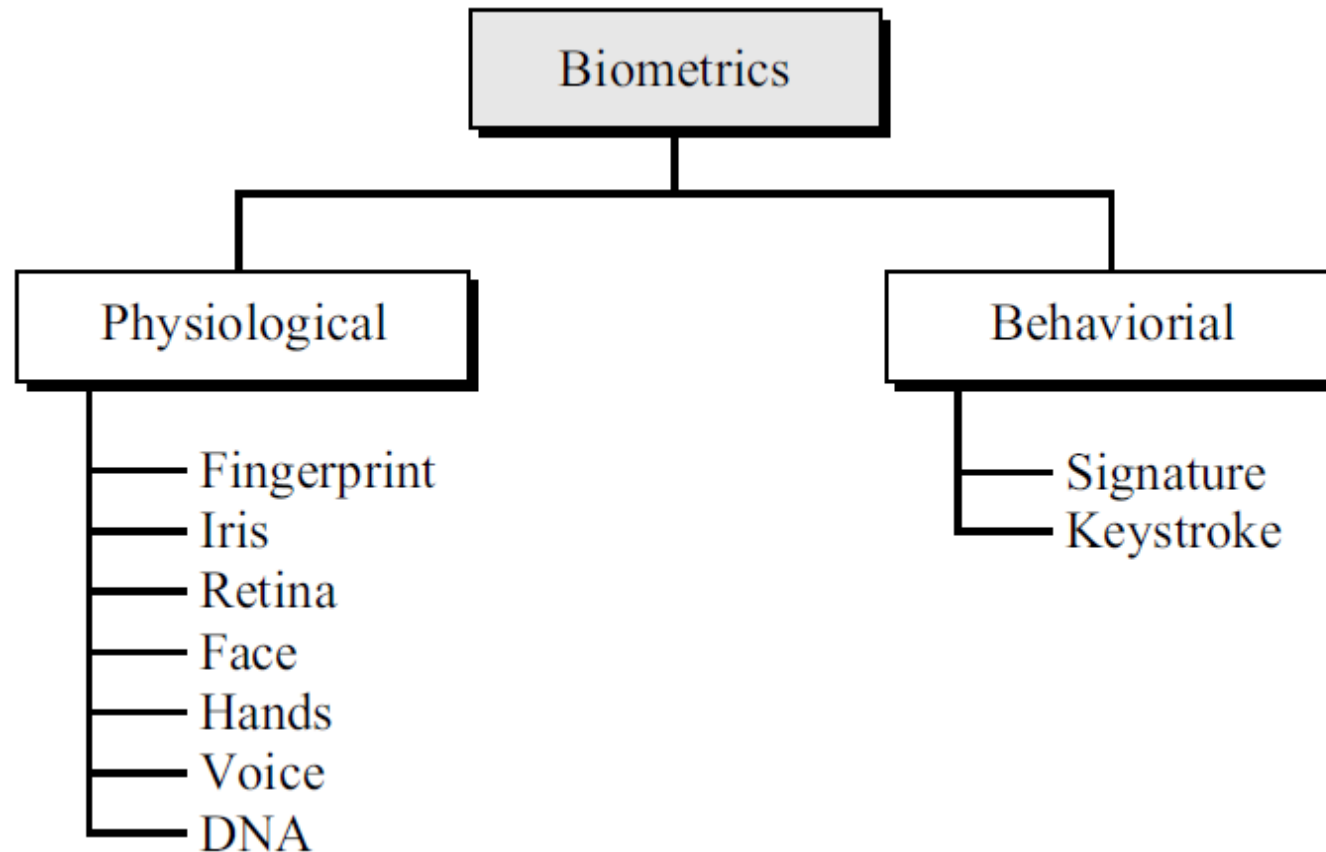
- In the next access, the counter $n - 1$ is replied to the user which responded with $h^{n-2}(P_0)$. **The identical processes is repeated until the counter n exhausted.**
- When it reaches 0, the user can no long access the system.
- To ensure the system is **accessible for a longer period**, the counter n chosen is normally a **larger number**. For example, $n = 1000$.



BIOMETRIC AUTHENTICATION

Biometric Authentication

- The **measurement of physiological** and **behavioural features** that identify a person.



Biometric Authentication – Advantages

1. **Enhanced Security**. Biometric authentication provides a higher level of security. It is '**something that a person is**' that cannot be guessed, stolen, or shared. It ensures **non-repudiation** property that a person cannot deny that he is someone.
2. **Convenience**. Users don't have to remember complex passwords or carry around security tokens.
3. **Improved User Experience**. Biometric authentication is quick, easy, and doesn't require any special skills or knowledge. This makes it an ideal choice for applications that require high levels of security, such as banking, healthcare, and government services.



Biometric Authentication – Disadvantages

1. **High Cost.** The hardware and software required for biometric authentication can be costly, and the systems need to be regularly updated and maintained to ensure their effectiveness.
 2. **Privacy Concerns.** Biometric authentication systems store sensitive information about individuals, such as their fingerprints or facial features.
 3. **Accuracy.** Biometric authentication systems may sometimes incorrectly identify individuals, leading to false positives.
- 



MULTI-FACTOR AUTHENTICATION

Multi-Factor Authentication

- This authentication technique **requires two or more mechanisms** to authenticate a user.
- It is sometimes called the **strong authentication** since a user must possess two or more information to identify/authenticate himself.
- It is the **combination** of the following three components:
 1. Something that you **know** (password).
 2. Something that you **have** (smartcard/badge).
 3. Something that you **are** (biometric).

Main References for Chapter 13

1. Forouzan, B.A. "***Introduction to Cryptography and Network Security***", Third Edition, McGraw-Hill, 2008.

~ THE END 😊 ~